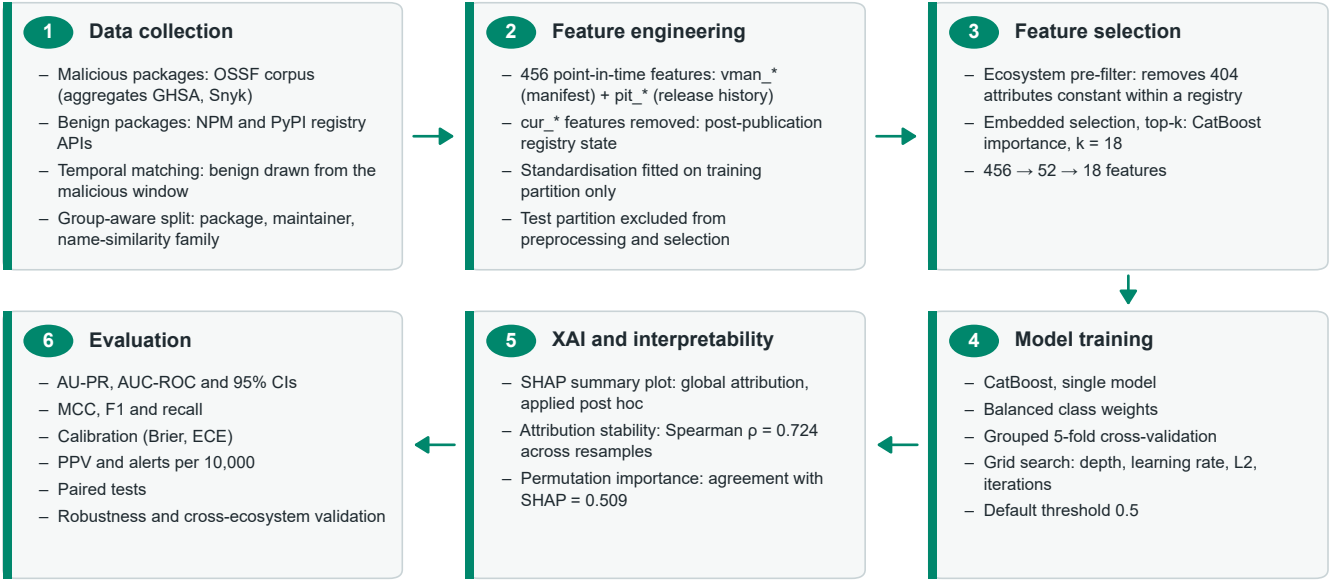
1
Data collection
– Malicious packages: OSSF corpus (aggregates GHSA, Snyk)
– Benign packages: NPM and PyPI registry APIs
– Temporal matching: benign drawn from the malicious window
– Group-aware split: package, maintainer, name-similarity family
2
Feature engineering
– 456 point-in-time features: vman_* (manifest) + pit_* (release history)
– cur_* features removed: post-publication registry state
– Standardisation fitted on training partition only
– Test partition excluded from preprocessing and selection
3
Feature selection
– Ecosystem pre-filter: removes 404 attributes constant within a registry
– Embedded selection, top-k: CatBoost importance, k = 18
– 456 → 52 → 18 features
4
Model training
– CatBoost, single model
– Balanced class weights
– Grouped 5-fold cross-validation
– Grid search: depth, learning rate, L2, iterations
– Default threshold 0.5
5
XAI and interpretability
– SHAP summary plot: global attribution, applied post hoc
– Attribution stability: Spearman ρ = 0.724 across resamples
– Permutation importance: agreement with SHAP = 0.509
6
Evaluation
– AU-PR, AUC-ROC and 95% CIs
– MCC, F1 and recall
– Calibration (Brier, ECE)
– PPV and alerts per 10,000
– Paired tests
– Robustness and cross-ecosystem validation